

THÔNG TIN CHUNG CỦA NHÓM

- Link YouTube video của báo cáo (tối đa 5 phút):

<https://www.youtube.com/watch?v=707SxVvfPh4>

- Link slides (dạng .pdf đặt trên Github của nhóm):

<https://github.com/KhoaHoang01012003/CS2205.CH203/blob/master/NGHI%3%8AN%20C%E1%BB%A8U%20V%C3%80%20T%C3%81I%20HI%E1%BB%86N%20PH%C6%AF%C6%A0NG%20PH%C3%81P%20PH%C3%81T%20HI%E1%BB%86N%20PHP%20WEBSHELL%20D%E1%BB%B0A%20TR%C3%8AN%20H%E1%BB%8CC%20%C4%90%E1%BB%92%20TH%E1%BB%8A.pdf>

- Họ và Tên: Hoàng Anh Khoa

- MSSV: 250202042



- Lớp: CS2205.CH203

- Tự đánh giá (điểm tổng kết môn): 9/10

- Số buổi vắng: 2

- Số câu hỏi QT cá nhân: 3

- Số câu hỏi QT của cả nhóm: 3

- Link Github:

<https://github.com/KhoaHoang01012003/CS2205.CH203>

ĐỀ CƯƠNG NGHIÊN CỨU

TÊN ĐỀ TÀI (IN HOA)

NGHIÊN CỨU VÀ TÁI HIỆN PHƯƠNG PHÁP PHÁT HIỆN PHP WEBSHELL DỰA TRÊN HỌC ĐỒ THỊ

TÊN ĐỀ TÀI TIẾNG ANH (IN HOA)

RESEARCH AND REIMPLEMENTATION OF GRAPH LEARNING-BASED PHP WEBSHELL DETECTION

TÓM TẮT

Đề tài dự kiến nghiên cứu và tái hiện một phương pháp phát hiện PHP webshell dựa trên học đồ thị, lấy cảm hứng từ framework GlareShell. Bài toán được đặt ra là phân loại một tệp PHP mới được tạo hoặc chỉnh sửa trên máy chủ web thành hai nhóm: webshell độc hại hoặc mã PHP thông thường. Đầu vào của bài toán là mã nguồn PHP tĩnh; đầu ra là nhãn dự đoán kèm các chỉ số đánh giá như Accuracy, Precision, Recall, F1-score và ma trận nhầm lẫn. Phương pháp dự kiến gồm bốn bước chính. Thứ nhất, các tệp PHP được thu thập, gán nhãn và chia thành tập huấn luyện, kiểm định và kiểm thử. Thứ hai, mỗi tệp PHP được biểu diễn dưới dạng đồ thị luồng điều khiển liên thủ tục, sau đó các câu lệnh được chuẩn hóa để giảm nhiễu do tên biến, hằng số và cách viết mã khác nhau. Thứ ba, mỗi nút trong đồ thị được gán thuộc tính bằng cách kết hợp biểu diễn ngữ nghĩa của câu lệnh với trọng số rủi ro dựa trên các hàm nhảy cảm trong PHP. Thứ tư, các mô hình mạng nơ-ron đồ thị như GCN, GAT và GIN được huấn luyện để phân loại tệp PHP.

Kết quả mong đợi là một pipeline tái hiện có thể chạy được, có báo cáo thực nghiệm định lượng và có so sánh với bài báo gốc. Đề tài không hướng đến việc triển khai công cụ phòng thủ hoàn chỉnh cho môi trường sản xuất, mà tập trung vào phương pháp nghiên cứu, khả năng tái hiện và đánh giá tính khả thi của hướng tiếp cận học đồ thị trong phát hiện PHP webshell.

GIỚI THIỆU

Webshell là một dạng mã độc thường được tải lên máy chủ web sau khi kẻ tấn công khai thác thành công lỗ hổng upload file, lỗ hổng CMS hoặc cấu hình sai. Với webshell, kẻ tấn công có thể thực thi lệnh, đọc dữ liệu nhạy cảm, duy trì quyền truy cập hoặc dùng máy chủ làm bàn đạp cho các hành vi khác. PHP là một ngôn ngữ phổ biến trong phát triển web, do đó PHP webshell vẫn là một vấn đề có tính thực tế trong an toàn thông tin.

Các phương pháp phát hiện truyền thống thường dựa vào chữ ký, từ khóa, thống kê văn bản hoặc đặc trưng thủ công. Những cách này có thể hiệu quả với mẫu quen thuộc nhưng dễ gặp khó khăn khi webshell bị làm rối mã, đổi tên biến, tách chuỗi hoặc dùng lời gọi hàm động. Bài toán nghiên cứu vì vậy không chỉ là tìm một số từ khóa nguy hiểm, mà là mô hình hóa hành vi và cấu trúc chương trình trong mã PHP.

Đề tài này xem mỗi tệp PHP như một đối tượng tính toán có thể được biểu diễn thành đồ thị. Các nút của đồ thị tương ứng với câu lệnh hoặc khối lệnh, các cạnh biểu diễn quan hệ luồng điều khiển. Input của hệ thống là tệp PHP tĩnh; output là nhãn phân loại webshell hoặc mã thông thường, kèm độ tin cậy và các chỉ số đánh giá. Cách trừu tượng hóa này giúp kết nối bốn trụ cột của computational thinking: phân rã pipeline thành các bước nhỏ, nhận diện mẫu rủi ro trong câu lệnh, trừu tượng hóa mã nguồn thành đồ thị và thiết kế thuật toán huấn luyện, đánh giá mô hình.

Lý do chọn đề tài là hướng tiếp cận GlareShell kết hợp static analysis, word embedding, risk weight và graph neural network, phù hợp để khảo sát cả phương pháp nghiên cứu lẫn thực nghiệm tái hiện. Nếu được triển khai đầy đủ, kết quả có thể hỗ trợ xây dựng công cụ quét tĩnh cho máy chủ web, kiểm tra mã PHP trước khi triển khai hoặc làm nền cho nghiên cứu sâu hơn về phát hiện mã độc dựa trên biểu diễn chương trình.



Hình 1. Luồng xử lý dữ kiện của đề tài

MỤC TIÊU

1. Xây dựng được pipeline tái hiện phương pháp phát hiện PHP webshell dựa trên học đồ thị, trong đó tệp PHP được chuyển thành đồ thị luồng điều khiển và được gán thuộc tính cho từng nút.
2. Huấn luyện và đánh giá các mô hình GNN tối thiểu gồm GCN, GAT và GIN trên dữ liệu PHP đã gán nhãn, sử dụng các chỉ số Accuracy, Precision, Recall, F1-score và ma trận nhầm lẫn.
3. Phân tích mức độ khả thi của phương pháp tái hiện bằng cách so sánh kết quả thực nghiệm với bài báo gốc, đồng thời ghi nhận rõ các sai khác về dữ liệu, môi trường và công cụ trích xuất đồ thị.

NỘI DUNG VÀ PHƯƠNG PHÁP

Nội dung 1: Khảo sát cơ sở lý thuyết và bài toán. Các công trình về phát hiện webshell, biểu diễn mã nguồn, static analysis và graph neural network sẽ được đọc để xác định input, output, giả thuyết nghiên cứu và các tiêu chí đánh giá. Kết quả của bước này là mô hình bài toán rõ ràng: phân loại tệp PHP tĩnh thành webshell hoặc benign.

Nội dung 2: Chuẩn bị dữ liệu và biểu diễn chương trình. Các mẫu PHP webshell và mã PHP thông thường sẽ được thu thập từ các nguồn công khai, sau đó được khử trùng lặp, tính hash, ghi manifest và chia tập dữ liệu theo seed cố định. Với mỗi tệp PHP, đồ thị ICFG dự kiến được trích xuất bằng LChecker hoặc một bộ chuyển đổi tương đương nếu môi trường bị giới hạn. Các câu lệnh được chuẩn hóa để giảm phụ thuộc vào tên biến, số cụ thể và cách đặt tên hàm người dùng.

Nội dung 3: Xây dựng thuộc tính nút. Mỗi câu lệnh sau chuẩn hóa sẽ được chuyển thành vector bằng kỹ thuật word embedding, ưu tiên FastText vì có khả năng xử lý token hiếm và biến thể từ. Song song đó, cơ chế risk weight sẽ gán mức rủi ro cho các câu lệnh chứa hàm nhạy cảm như eval, system, exec, shell_exec hoặc base64_decode. Vector cuối cùng của nút là sự kết hợp giữa embedding và trọng số rủi ro.

Nội dung 4: Huấn luyện và đánh giá mô hình. Các mô hình GCN, GAT và GIN sẽ được huấn luyện trên graph dataset. Tập validation được dùng để chọn checkpoint tốt nhất; tập test chỉ dùng cho đánh giá cuối. Các kết quả được trình bày bằng bảng metric, ma trận nhầm lẫn và so sánh giữa các kiến trúc mô hình. Những trường hợp dự đoán sai sẽ được phân tích để nhận diện giới hạn của phương pháp.

Nội dung 5: Đảm bảo an toàn khi thực nghiệm. Pipeline chính chỉ phân tích tĩnh, không thực thi webshell. Các mẫu mã độc được xử lý như dữ liệu đầu vào để trích xuất đặc trưng, không được chạy trực tiếp trên máy thật. Nếu cần kiểm tra runtime, môi trường cô lập hoặc container sẽ được dùng và có ghi rõ phạm vi an toàn.

KẾT QUẢ MONG ĐỢI

- Một bộ mã nguồn tái hiện pipeline phát hiện PHP webshell gồm thu thập dữ liệu, trích xuất đồ thị, chuẩn hóa câu lệnh, xây dựng thuộc tính nút, huấn luyện GNN và xuất báo cáo.
- Một tập artifact thực nghiệm gồm manifest dữ liệu, split train/validation/test, graph cache, checkpoint mô hình, metrics.json, confusion matrix và file dự đoán trên tập test.
- Bảng so sánh định lượng giữa ít nhất ba mô hình GNN: GCN, GAT và GIN. Các chỉ số chính gồm Accuracy, Precision, Recall và F1-score.

- Một báo cáo ngắn chỉ ra kết quả nào có thể tái hiện gần với bài báo gốc, kết quả nào sai khác và nguyên nhân sai khác do dữ liệu, công cụ LChecker hoặc cấu hình huấn luyện.
- Một demo quét tĩnh an toàn cho tệp PHP đơn lẻ, trả về nhãn dự đoán webshell hoặc benign mà không thực thi mã PHP đầu vào.

TÀI LIỆU THAM KHẢO

- [1]. Pengbin Feng, Dawei Wei, Qiaoyang Li, Qin Wang, Youbing Hu, Ning Xi, Jianfeng Ma: GlareShell: Graph learning-based PHP webshell detection for web server of industrial internet. Comput. Networks 245: 110406 (2024)
- [2]. Yu Li, Jin Huang, Ademola Ayodeji Ikusan, Milliken Mitchell, Junjie Zhang, Rui Dai: ShellBreaker: Automatically detecting PHP-based malicious web shells. Comput. Secur. 87: 101595 (2019)
- [3]. Yong Fang, Yaoyao Qiu, Liang Liu, Cheng Huang: Detecting Webshell Based on Random Forest with FastText. ICCAI 2018: 52-56
- [4]. Thomas N. Kipf, Max Welling: Semi-Supervised Classification with Graph Convolutional Networks. CoRR abs/1609.02907 (2016)
- [5]. Petar Velickovic, Guillem Cucurull, Arantxa Casanova, Adriana Romero, Pietro Liò, Yoshua Bengio: Graph Attention Networks. ICLR 2018
- [6]. Keyulu Xu, Weihua Hu, Jure Leskovec, Stefanie Jegelka: How Powerful are Graph Neural Networks? ICLR 2019